SecurePsych AI

Feature POC Checklist: RAG Service

Version 1.0 | CSIS494 | March 2026

Feature	FERPA Compliance & Audit Readiness
Owner	Jon T.
Service Port	N/A - documentation deliverable, not a microservice
Scope	Legal analysis, filesystem structure, encryption, audit artifacts, district lawyer packet
Purpose	Minimum bar for district lawyer review and stakeholder demo readiness
Phase Gate	Phase 3 - required before April stakeholder demo

1. What This Checklist Is

This is a **compliance acceptance checklist**, not a task list. The deliverables here are documentation and verification artifacts - not code. The primary audience for these outputs is **district legal counsel**. Before the April stakeholder demo, every item must be checked. Items are organized by concern: legal analysis, filesystem structure, encryption, audit infrastructure, and the documentation packet for external review.

Note on scope: Jon T. owns the compliance deliverables. Architecture decisions driven by compliance findings must be flagged to Natoli (EL) immediately - do not wait until the memo is complete. Any legal interpretations that require external counsel must be escalated to Kai (PM) and Dr. Andrew Chen before being included in the district lawyer packet.

2. Acceptance Criteria

A. Legal Analysis

#	Acceptance Criterion	Notes / Threshold
1	Written memo addressing whether running a local LLM on school-owned hardware with zero external data transmission constitutes a FERPA-covered "disclosure" under 34 CFR Part 99.	Cite specific CFR section. Conclusion must be defensible to a district lawyer. This is the most critical external deliverable.
2	Clear distinction documented between "FERPA-labeled" (cloud, contractual) and "FERPA-compliant" (technical, hard-coded). The memo must explain why the on-prem architecture satisfies the technical standard rather than the contractual one.	Use the comparison table from the initial research doc. Show the Feature / FERPA-Labeled / FERPA-Compliant matrix.
3	IDEA (34 CFR Part 300) and COPPA (16 CFR Part 312) adjacency flags documented - note any requirements that apply to the specific use case (students ages 3–21 with disability evaluations).	Flag anything that requires an architecture change. If no change is needed, state that explicitly.
4	Minnesota-specific statutes reviewed: MSDPA (Minn. Stat. § 13.32) and MGDPA (Minn. Stat. § 13) checked for any requirements beyond federal FERPA.	Flag any state-level additions that go beyond the federal standard. Reference the statute URLs from the FERPA research doc.

B. Filesystem & Encryption

#	Acceptance Criterion	Notes / Threshold
5	CIS-recommended partition scheme implemented and documented on the server: separate partitions for /home, /var, /var/log, /var/log/audit, and /var/tmp; tmpfs mounts for /tmp and /dev/shm.	Verified by Arpita H. (IT Lead) and documented in OneDrive. Jon T. confirms documentation is accurate against actual server config.
6	LUKS full-disk encryption active on the student data partition. fscrypt file-level encryption active on the shared student data directory. Both verified post-setup.	Test: physically remove drive - data must be unreadable without the key. Document key management procedure.
7	TLS 1.3 configured for all browser-to-server communication on the local network. Internal traffic is not plaintext even on the school LAN.	Verify with a network capture on the school Wi-Fi during a test query session.
8	All FastAPI services containerized in Docker. Containers cannot write outside of the designated encrypted volume mount. Docker volume config reviewed.	Docker volume configuration reviewed by Natoli at PR time. Jon T. confirms the isolation claim is accurate for the compliance memo.
9	Cryptographic module implementation follows FIPS 140-3 (the 2026 updated standard). Document which library versions are used and confirm FIPS compliance status.	Note specific library versions and their FIPS 140-3 certification status in the compliance memo.

C. Audit Infrastructure

#	Acceptance Criterion	Notes / Threshold
10	Tamper-evident audit log active: every document upload, query, and summarization request is logged with timestamp, user ID, and action type. No PII appears in the log output.	Produce a sample log output (redacted if needed) for the district lawyer packet. Confirm no student names or document content appear in logs.
11	Data retention and destruction policy written: document how the district can hard-delete a student's data upon request or graduation, including the specific commands or UI flow a non-developer can follow.	One-page technical guide written for a non-developer audience (school IT administrator, not an engineer).
12	Zero-outbound-network verification: during a full demo run (ingest + query + summarize), curl api.openai.com fails with connection refused. Screenshot or terminal capture saved.	This is both a security check and a demo talking point. Save the terminal capture as a file in OneDrive - bring it to the April stakeholder meeting.

D. External-Facing Documentation Packet

The items below are the deliverables a district lawyer will read. They must be complete, printed, and available at the April stakeholder demo.

#	Acceptance Criterion	Notes / Threshold
13	System Data Flow Map: a visual diagram showing every data pathway - upload → ingest → vector store → query → response - with an explicit annotation that no data packet exits the LAN at any step.	One page, suitable for printing and handing to a lawyer. Must be visually clear to a non-engineer.
14	Privacy Impact Assessment (PIA): what PII is collected, why it is necessary, who can access it, and how long it is retained.	One to two pages. Written in plain language. Not a technical spec - a policy document.
15	Compliance memo finalized in formal register, printable, and referenced by name in the project roadmap. Available at the April stakeholder demo.	This is the most critical external deliverable. Natoli reviews the final draft before printing. District lawyers are the actual decision-makers for tool adoption.

3. What Is Explicitly Out of Scope for This Checklist

The following are not required for this checklist and are tracked separately:

- Frontend UI - tracked under Alyse B. / Zach M. frontend work.
- LangSmith metadata audit (confirming no document content transmitted) - tracked under Natoli, Phase 3 security audit.
- Multi-school or district-level compliance - post-April demo scope.
- Performance benchmarking - tracked in Summarization and RAG POC checklists.

4. How to Use This Checklist

Jon T. completes each item and submits the documentation packet to Natoli for review **no later than April 8**. Natoli confirms the packet is complete before it is printed for the April stakeholder demo. Any legal questions that require external counsel should be escalated to Kai (PM) and Dr. Andrew Chen **immediately** - do not make legal interpretations without review.

When the documentation packet is ready, open a PR (or equivalent OneDrive review request) and paste this checklist with each item checked off and evidence noted. Any unchecked item needs an explicit decision: fix it, defer it with justification, or accept it as a known gap with Natoli's sign-off.

5. Key Reference Links

FERPA Overview (ED.gov): https://www2.ed.gov/policy/gen/guid/fpco/ferpa/index.html
IDEA Part B (34 CFR Part 300): https://www.ecfr.gov/current/title-34/subtitle-B/chapter-III/part-300
COPPA (16 CFR Part 312): https://www.ecfr.gov/current/title-16/chapterI/subchapter-C/part-312
Minnesota MSDPA: https://www.revisor.mn.gov/statutes/cite/13.32
Minnesota MGDPA: https://www.revisor.mn.gov/statutes/cite/13
CIS Controls: https://www.cisecurity.org/controls